ONE-PAGE BRIEF

Post-quantum cryptography review: krux @ 9b3a4314a205

Client: Krux (selfcustody) — public repository (passive review) · Source: github.com/selfcustody/krux, commit `9b3a4314a205` · Reviewed: 2026-11-04 18:52 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **2** High **6** Medium

0 Low **3** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 5 − 8 = 7 → **too late**

Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High QSI-2026-11969	**ECB block-cipher mode used in src/krux/kef.py** confirmed by the analyst What to do: Use an AEAD mode (GCM) with unique nonces.
High QSI-2026-11978	**Non-cryptographic generator next to key or seed generation in vendor/embit/src/embit/util/key.py** preliminary What to do: Use the platform CSPRNG (secrets, os.urandom, crypto.getRandomValues, crypto/rand, SecureRandom, OsRng) or a hardware TRNG for every key...
Medium QSI-2026-11972	**Quantum-vulnerable ECDSA: transaction and message signing (31 file(s))** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...
Medium QSI-2026-11974	**Quantum-vulnerable Schnorr (BIP-340): transaction and message signing (7 file(s))** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...

4 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium threshold signing and MPC protocols	Pedersen commitment	Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the...
Medium transaction and message signing	ECDSA, Schnorr (BIP-340)	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium role not determined	ECDSA, ECDH, Schnorr (BIP-340)	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

Analyst review: 7 confirmed, 3 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-29)

Static review of source code and manifests; files analysed: 246. No requests were sent to the owner's systems.

Full report, content SHA-256: `e013074c7b0eda8ff8256cc33f333800e595ae0c48705d84b95076950e74be8d`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.